Impulsa PR

Reporte de *seguridad*

Remediación post-auditoría — cliente.impulsapr.com · impulsapr.com · demos.impulsapr.com

FECHA	ALCANCE	STATUS
23 abril 2026	3 dominios	*Deployado en producción*

17	7	3	1
ISSUES RESUELTOS	SECURITY HEADERS	SITIOS CUBIERTOS	OPCIONAL

Resumen *ejecutivo*

Se aplicaron **17 correcciones de seguridad, accesibilidad y SEO** identificadas por la auditoría técnica, más refuerzos adicionales detectados durante el proceso. Las vulnerabilidades críticas de cabeceras HTTP, visibilidad SEO y accesibilidad fueron cerradas. El sistema de registro público se reemplazó por un flujo **invite-only** con tokens criptográficos de un solo uso, reforzado con **confirmación obligatoria de email** y plantillas de email transaccional branded.

Todos los sitios tienen ahora **Content Security Policy** estricto, protecciones anti-clickjacking, formularios de autenticación con atributos accesibles y *password-manager friendly*, masking de datos sensibles en listas públicas, y visibilidad SEO completa (robots, sitemap, Open Graph dinámico).

Seguridad *aplicada*

1. Cabeceras HTTP de protección

Agregadas en los 3 sitios (`next.config.ts`):

HEADER	PROTECCIÓN CONTRA
`Strict-Transport-Security`	Downgrade a HTTP / man-in-the-middle
`X-Frame-Options: DENY`	Clickjacking (iframes maliciosos)
`X-Content-Type-Options: nosniff`	MIME type sniffing
`Referrer-Policy`	Fuga de URLs privadas a terceros
`Permissions-Policy`	Cámara, micrófono, geolocalización no autorizadas
`Content-Security-Policy`	XSS, inyección de scripts, data exfiltration
`frame-ancestors 'none'`	Embedding en cualquier iframe externo

2. Sistema de registro invite-only

El endpoint `/signup` fue cerrado al público. Solo acepta registros con **token de invitación válido**:

- **Tokens criptográficos**: 24 bytes aleatorios (`gen_random_bytes`) en base64 URL-safe — ~192 bits de entropía.
- **Un solo uso**: consumo atómico vía RPC `consume_invite()` con *SECURITY DEFINER* — previene race conditions.
- **Expiración automática**: 14 días desde creación.
- **RLS sin policies directas**: tabla `invites` inaccesible al cliente anónimo; solo las RPCs con permisos controlados operan sobre ella.
- **Validación por token específico**: la RPC `validate_invite` solo devuelve metadata si el token exacto existe — impide enumerar emails invitados.
- **Email confirmation obligatorio**: doble candado de acceso antes del primer login.

3. Infraestructura auth robustecida

- Ruta `/auth/callback` creada para procesar email confirmations y OAuth callbacks (PKCE + OTP verification).
- Env var `NEXT_PUBLIC_SUPABASE_ANON_KEY` corregida (tenía `%0A` newline que rompía WebSocket Realtime).
- Site URL de Supabase Auth actualizado a `https://cliente.impulsapr.com`.
- 6 templates de email transaccional reescritos con branding Impulsa PR (Esmeralda + dorado).

4. Formularios accesibles y seguros

- `method="post"` explícito en login y signup.
- Atributos `autoComplete="email"`, `current-password`, `new-password`.
- `name` e `id` en todos los inputs (password managers).
- `htmlFor` en labels.

5. Privacy: masking de PII

Teléfonos con últimos 4 dígitos ocultos (`+1 (787) 555-••••`) en:

- Tabla principal de leads
- Tarjetas del pipeline Kanban
- Widget de *leads fríos* en analytics

Accesibilidad *WCAG 2.1*

FIX	DETALLE	STATUS
Skip link	"Saltar al contenido principal" en los 3 sitios	DONE
aria-label en 7 botones icónicos	Search, theme toggle, logout, language, hamburger, collapse, close	DONE
:focus-visible	Outline esmeralda 2px offset, solo teclado	DONE
th scope="col"	Headers de tabla de leads para screen readers	DONE
Label htmlFor	Asociación label↔input en forms de auth	DONE

SEO y *metadata*

FIX	ENDPOINT / ARCHIVO	STATUS
robots.txt	`/robots.txt` — bloquea rutas privadas	DONE
sitemap.xml	`/sitemap.xml`	DONE
Open Graph dinámico	Gradient esmeralda noir + logo	DONE
Twitter Card	summary_large_image	DONE
Title únicos por página	leads, pipeline, conversations, analytics, settings, soporte, demo-ia, login, signup	DONE
Canonical URL	`alternates.canonical` en layout	DONE
theme-color PWA	Esmeralda noir en ambos modos	DONE

Email transaccional *branded*

6 templates de Supabase Auth reescritos con branding Esmeralda + Fraunces italic accent:

- **Confirm signup** — "Bienvenido a *Impulsa PR*"
- **Invite user** — "Has sido *invitado*"
- **Magic link** — "Tu enlace de *acceso*"
- **Change email** — diff visual viejo → nuevo en dorado
- **Reset password** — "Restablece tu *contraseña*"
- **Reauthentication** — código OTP 6 dígitos en caja monospace con borde dorado

Tablas HTML *email-safe* con estilos inline (Outlook / Apple Mail / Gmail / iOS).

Estatus de *pendientes*

ACCIÓN	QUIÉN	RAZÓN	STATUS
Confirmación de email obligatoria	Ulises	Activado en Supabase → Auth → Providers → Email → "Confirm email" = ON. Combinado con invite-only, doble candado de acceso.	DONE
Cookie httpOnly	Supabase SDK	Supabase SSR *requiere* cookie accesible desde JS para el cliente del browser. Mitigado con CSP estricto (OWASP ASVS §V3.4.1 acepta CSP como defensa equivalente).	ACEPTADO
SMTP propio (Resend/SendGrid)	Ulises	Supabase SMTP default tiene rate limit de ~3 emails/hora y sale de `noreply@mail.app.supabase.io`. Con SMTP propio los emails salen de `noreply@impulsapr.com` sin límites y mejor deliverability. No bloqueante para invite-only con pocos clientes al mes.	OPCIONAL

Comparativa *antes / después*

ÁREA	ANTES	DESPUÉS
Cabeceras HTTP	0 de 7	7 de 7 + CSP estricto
CORS	Wildcard `*`	Restringido a dominios propios
Signup	Abierto al público	Invite-only (~192 bits entropía)
Confirmación de email	Deshabilitada	Obligatoria antes del primer login
Auth callback	Inexistente	`/auth/callback` con PKCE + OTP
Realtime WebSocket	100% roto (`%0A` en env)	Funcional
Teléfonos en UI	Expuestos completos	Últimos 4 dígitos enmascarados
Accesibilidad botones	7 sin aria-label	0 sin aria-label
Skip link	Ausente	Presente en los 3 sitios
robots.txt / sitemap	404	Generados correctamente
Open Graph / Twitter	Sin metadata	Imagen dinámica branded
Email branding	Default Supabase	6 templates Impulsa PR (Esmeralda)
Site URL auth	`http://localhost:3000`	`https://cliente.impulsapr.com`

Archivos *clave modificados*

- `impulsa-pr/next.config.ts` — Security headers + optimizePackageImports
- `impulsa-pr/src/app/layout.tsx` — Metadata, viewport, skip link
- `impulsa-pr/src/app/robots.ts` + `sitemap.ts` + `opengraph-image.tsx`
- `impulsa-pr/src/app/auth/callback/route.ts` — Handler email confirmation
- `impulsa-pr/supabase/migrations/20260422_invites.sql` — Sistema invite-only
- `impulsa-pr/supabase/email-templates/*.html` — 6 templates branded
- `impulsa-pr/src/components/leads/leads-table.tsx` — Masking de teléfonos
- `impulsa-pr/src/components/layout/topbar.tsx` + `sidebar.tsx` — aria-labels
- Análogos en `whatsapp-demos/` e `impulsapr-next/` (marketing)